

CodeAlpha Task 3 - Secure Coding Review

Overview

This repository contains my submission for **Task 3: Secure Coding Review** as part of the **CodeAlpha Cyber Security Internship**.

The objective of this project was to review a Python application for security vulnerabilities, identify potential risks using a Static Application Security Testing (SAST) tool, implement secure coding practices, and verify the improvements through rescanning.

Project Objectives

- Review a Python application for security vulnerabilities.
- Perform static code analysis using Bandit.
- Identify insecure coding practices.
- Implement remediation techniques.
- Validate the security improvements through a second security scan.

Technologies Used

- Kali Linux
- Python 3
- Bandit (Static Application Security Testing Tool)
- Nano Text Editor

Project Files

```
CodeAlpha_Secure_Review/
├── insecure_login.py      # Vulnerable Python application
├── secure_login.py        # Remediated version
├── bandit_report.txt      # Bandit scan report
├── Secure_Coding_Review_Report.pdf
└── README.md
```

Methodology

The following steps were performed during the secure coding review:

1. Developed a vulnerable Python login application.
2. Executed the application to understand its functionality.
3. Performed a static security scan using Bandit.
4. Analyzed the identified vulnerability.
5. Improved the application's security by implementing secure coding practices.

6. Rescanned the updated application.
7. Compared the results before and after remediation.

Vulnerability Identified

Command Injection (Bandit B605)

Bandit detected a **High Severity** vulnerability caused by the use of:

```
```python
os.system(command)
```
```

This function executes operating system commands directly from user input without validation, making the application vulnerable to command injection attacks.

Risk

An attacker could execute arbitrary operating system commands, potentially resulting in:

- Unauthorized system access
- Remote code execution
- Data theft
- File deletion
- System compromise

Remediation

The following security improvements were implemented:

- Removed unsafe command execution.
- Added file existence validation.
- Implemented exception handling.
- Improved input validation.
- Applied secure coding best practices.

Scan Results

Initial Scan

| Severity | Issues |
|----------|--------|
| High | 1 |
| Medium | 0 |
| Low | 0 |

Bandit identified one **High Severity** vulnerability (B605 - Command Injection).

Final Scan

| Severity | Issues |
|----------|--------|
| High | 0 |
| Medium | 0 |
| Low | 0 |

Bandit reported:

> **No issues identified.**

Learning Outcomes

This project improved my understanding of:

- Secure coding principles
- Static Application Security Testing (SAST)
- Python application security
- Vulnerability assessment
- Risk analysis
- Secure software development
- Code remediation techniques

How to Run the Project

Clone the repository:

```
```bash
git clone https://github.com/yourusername/CodeAlpha_Secure_Review.git
```
```

Navigate into the project directory:

```
```bash
cd CodeAlpha_Secure_Review
```
```

Run the vulnerable application:

```
```bash
python3 insecure_login.py
```
```

Run the secure application:

```
```bash
python3 secure_login.py
```
```

Scan the vulnerable application:

```
```bash
```

```
bandit insecure_login.py
```
```

Scan the secure application:

```
```bash
bandit secure_login.py
```
```

Project Outcome

The project successfully demonstrated the process of identifying and mitigating security vulnerabilities in a Python application. After implementing secure coding practices, the remediated application passed the Bandit security scan with **no identified issues**, indicating a significant improvement in the application's security posture.

Author

Olore Bolaji

Cyber Security Intern - CodeAlpha

GitHub: <https://github.com/cyberbee265>

LinkedIn: <https://linkedin.com/in/sulaimon-olore-7495b116b>

License

This project was developed solely for educational purposes as part of the CodeAlpha Cyber Security Internship Program.